Rubrics for Final Project (100 points)

1. Authentication & User Roles – 17 Points

Criteria	Points
Working Login & Logout System	6
Proper Password Hashing & Security	5
Correct Role Implementation (Admin & Staff)	4
Unauthorized access properly blocked	2

2. Authorization & Access Control – 11 Points

Criteria	Points
Role-based route protection (security.yaml / Controller)	5
Proper access denial (403 / redirect)	3
Role checks in controller & templates	3

3. Admin Features – 19 Points

Feature	Points
Create users/staff	5
Update user/staff	4
Delete user/staff	4
View all data records	3
Admin dashboard (total users, total staff, total records)	3

4. Staff Features – 16 Points

Feature	Points
Create records (products, posts, etc.)	6
Edit own records	6
View records	4

Note: Staff must not access admin-only pages.

5. CRUD Functionality – 15 Points

Criteria	Points
Create	4
Read	3
Update	4
Delete with confirmation	4

6. Validation, Errors & Security – 11 Points

Criteria	Points
Form validation	4
Flash messages	2
CSRF protection	3
No plain-text passwords	2

7. User Interface & Usability – 8 Points

Criteria	Points
Clean layout & navigation	3
Role-based menu display	2
Mobile readability	3

8. Code Quality & Project Structure – 3 Points

Criteria	Points
Clean controller usage	1
Proper entity & repository usage	1
Organized templates & routes	1

TOTAL = 100 POINTS

Category	Points
Authentication & Roles	17
Authorization	11
Admin Features	19
Staff Features	16
CRUD Operations	15
Security & Validation	11
UI & Usability	8
Code Quality	3
TOTAL	**100**

Rubrics for Final Project (100 points)

Category	Points	Actual Points
Authentication & Roles	17	
Authorization	11	
Admin Features	19	
Staff Features	16	
CRUD Operations	15	
Security & Validation	11	
UI & Usability	8	
Code Quality	3	
TOTAL	**100**	

REQUIRED SYSTEM FUNCTIONS

These functions are MANDATORY for a passing project.

ADMIN FUNCTIONS

1. Authentication & Account Control

- Login
- Logout
- Change own password
- View own account profile

2. Staff Management (CRUD)

- Create new user accounts
  - Admin
  - Staff
- View all user accounts
  - Username / Email
  - Role
  - Date created
- Edit user accounts
  - Change name
  - Change email
  - Change role
  - Reset password
- Delete user accounts
  - With confirmation
- Disable or archive staff accounts (or statuses of accounts)

3. Admin Dashboard

- Total users
- Total staff
- Total records (products, posts, etc.)

4. Full Data Access (System-Wide)

- View ALL records created by staff
- Edit ANY record
- Delete ANY record
- Search & filter records

5. Security & Access Control (Admin Side)

- Admin-only routes must be protected by:
  - security.yaml role rules
  - Controller-level checks
  - Twig role-based menu visibility
- Staff must NOT access:
  - User management
  - Admin dashboard

STAFF FUNCTIONS

1. Authentication

- Login
- Logout
- View own profile
- Change own password

2. Record Management (CRUD – LIMITED)

- Create new records (e.g. Products, Posts, Students, Orders – depends on your system)
- View records
  - Own records
  - Or all shared records (depends on your system)
- Edit own records only
  - Cannot edit admin records
  - Cannot edit other staff records
- Delete own records only
  - With confirmation prompt

3. Access Restrictions (VERY IMPORTANT)

- Staff must NOT be able to:
  - Create staff/admin accounts
  - Access admin dashboard
  - Delete other users
  - Change system roles
- If staff bypasses a URL manually → system must return:
  - 403 Access Denied OR
  - Redirect to login/dashboard